

MP Sales Workflow — instrukcja instalacji (techniczna)

Wymagania, stałe w wp-config.php, poczta, cron, role i profile handlowców, deinstalacja. Dla administratora serwera lub osoby wdrażającej.

Wymagania

- WordPress 6.0 lub nowszy.
- PHP 7.4 lub nowszy (kod nie używa składni z PHP 8 — działa też na 8.x).
- MySQL 5.7+ / MariaDB 10.3+ z silnikiem InnoDB. Na MyISAM wtyczka zadziała, ale nie założy dwóch więzów ON DELETE CASCADE — usunięcie procesu nie posprząta wtedy zadań i powiadomień.
- HTTPS na całej witrynie — wymagane, nie zalecane (uzasadnienie w rozdziale „Stałe”).
- Dostęp do pliku wp-config.php oraz do systemowego crontab-a.

Wtyczka nie wymaga WooCommerce ani żadnej biblioteki zewnętrznej. Nie rejestruje własnych tras REST i nie wykonuje żadnych połączeń sieciowych w trakcie obsługi żądania.

Kolejność wdrożenia

1. Kopia zapasowa bazy (wp db export kopia-przed-wdrozeniem.sql).
2. Stałe w wp-config.php — PRZED aktywacją wtyczki.
3. Wgranie plików do wp-content/plugins/mp-sales-workflow i aktywacja.
4. Poczta (SMTP + rekordy DNS), cron systemowy, blokada katalogu z PDF-ami.
5. Uzupełnienie profili handlowców.
6. Smoke-test uprawnień na koncie testowym.

Stałe w wp-config.php (obowiązkowe)

Obie wartości mają mieć minimum 32 bajty losowe i muszą znaleźć się w wp-config.php — nigdy w kodzie wtyczki ani w bazie. Wtyczka nie ma żadnego zapasowego klucza trzymanego w bazie: przy braku stałej po prostu odmawia działania danej funkcji.

```
define( 'MP_HASH_PEPPER', '...64 znaki hex...' );
```

```
define( 'MP_SW_LINK_KEY', '...64 znaki hex...' );
```

Generowanie — każdą stałą osobno, nie tę samą wartość dwa razy: openssl rand -hex 32

Co się dzieje, gdy stałej brakuje

- **MP_SW_LINK_KEY** — wtyczka nie zbuduje linku do oferty, więc krytyk odrzuci powiadomienie do klienta (kod MP3-E500, powód unresolved_markers). E-maile do klientów przestaną wychodzić. To zamierzone: lepszy brak wysyłki niż wysyłka z martwym odnośnikiem.
- **MP_HASH_PEPPER** — dziennik techniczny zapisuje pusty hasz IP zamiast haszować bez soli. Też zamierzone: hasz adresu IPv4 bez soli odwraca się tęczową tablicą w kilka minut, więc byłby zapisem adresu wprost.

Rotacja **MP_SW_LINK_KEY**

Zmiana klucza unieważnia wszystkie linki wysłane wcześniej (ważność linku to 14 dni). Klient, który dostał ofertę wczoraj, zobaczy komunikat „Link jest nieprawidłowy”. Rotuj tylko przy podejrzeniu wycieku i uprzedź handlowców, że oferty trzeba wysłać ponownie.

Dlaczego HTTPS jest wymagane

Link do oferty niesie podpis HMAC w adresie. Po HTTP podpis wędruje jawnie i każdy pośrednik po drodze może go przechwycić i pobrać cudzą ofertę. Ustaw certyfikat, przekierowanie 301 z http na https, WP_HOME i WP_SITEURL ze schematem https oraz nagłówek Strict-Transport-Security.

Poczta

Wtyczka wysyła przez wp_mail(). Domyślnie PHP nadaje pocztę z serwera, który zwykle nie jest wpisany w rekordy nadawcze domeny — takie wiadomości lądują w spamie albo są odrzucane, czyli oferta do klienta nie dociera.

SMTP

Skonfiguruj uwierzytelnioną wysyłkę przez serwer poczty klienta lub dostawcę transakcyjnego. Hasło SMTP trzymaj w wp-config.php, nie w bazie. Nadawca ustawiany przez wtyczkę to oferty@<domena-witryny> — ten adres musi istnieć i mieć skrzynkę, żeby odpowiedzi klientów gdzieś trafiały.

Rekordy DNS

- **SPF** — jeden rekord TXT na domenę, wskazujący serwer SMTP z punktu wyżej.
- **DKIM** — podpis kryptograficzny wiadomości; klucz publiczny w DNS, prywatny na serwerze poczty.
- **DMARC** — startuj od p=none z adresem raportów, po tygodniu podnieś do p=quarantine.

Weryfikacja: wyślij ofertę testową na konto Gmail i sprawdź w nagłówkach Authentication-Results, czy jest spf=pass i dkim=pass.

Bezpiecznik wysyłki

Wtyczka pilnuje limitu 200 wiadomości na godzinę. Po przekroczeniu ustawia opcję

mp_sw_queue_halted, zatrzymuje kolejkę i pokazuje administratorowi komunikat z przyciskiem wznowienia. Powód: nadmiarowa wysyłka to jedyna szkoda w tym systemie, której nie da się cofnąć — po wpisaniu domeny na czarną listę w spam trafia nie jedna wiadomość, tylko cała późniejsza poczta firmy.

Limit podnosi się filtrem mp_sw_mail_max_per_hour, gdy klient realnie wysyła więcej ofert.

Cron

Domyślny wp-cron odpala się przy okazji odwiedzin strony. Na witrynie z małym ruchem zadania follow-up nie odpalą się w porę, a przy dużym — odpalą się kilka razy naraz.

1. Wyłącz cron „przy okazji”

```
define( 'DISABLE_WP_CRON', true );
```

2. Wpis w systemowym crontabie

Zadania wtyczki: mp_sw_sweep_tasks (co godzinę), mp_sw_retention (raz dziennie), mp_sw_run_queue (jednorazowe, planowane na +60 s, gdy w kolejce zostały wiadomości). Kolejka e-mail wychodzi więc z opóźnieniem równym odstępowi w crontabie — dlatego co minutę, nie co 15.

```
* * * * * cd /var/www/html && /usr/local/bin/wp cron event run --due-now --quiet >/dev/null 2>&1
```

WP-CLI ustawia stałą DOING_CRON, więc wartownik kontekstu w MP_SW_Cron::sweep_tasks() przeprowadza takie wywołanie. Gdyby WP-CLI nie było dostępne, zadziała też wywołanie lokalne: curl -s -o /dev/null http://127.0.0.1/wp-cron.php?doing_wp_cron

3. Zablokuj wp-cron.php z zewnątrz

nginx: location = /wp-cron.php { allow 127.0.0.1; allow ::1; deny all; }

Apache (.htaccess w katalogu głównym): <Files "wp-cron.php"> Require local </Files>

Sprawdzenie: curl -I https://domena/wp-cron.php z zewnątrz ma zwrócić 403. Samo odpalanie zadań nie pozwala wysłać powiadomienia z podstawionymi danymi — pilnuje tego macierz pochodzenia zdarzeń — ale blokada odcina wywoływanie harmonogramu w kółko.

Blokada katalogu z ofertami PDF

Pliki PDF generuje Plugin 2 do katalogu wp-content/uploads/mp-offer-builder-private/. Plugin 2 zakłada tam plik .htaccess z regułą Require all denied — to działa wyłącznie na Apache'u. Nginx plików .htaccess nie czyta w ogóle, więc na nim katalog pozostaje otwarty i oferty wszystkich klientów są do pobrania po zgadnięciu nazwy pliku.

nginx — dodaj do bloku server: location ^~ /wp-content/uploads/mp-offer-builder-private/ { deny all; return 404; }

Apache — sprawdź, że .htaccess w tym katalogu istnieje i że AllowOverride nie jest ustawione na None (przy None plik jest ignorowany).

Sprawdzenie: curl -I https://domena/wp-content/uploads/mp-offer-builder-private/dowolna.pdf ma zwrócić 403 albo 404 — nie 200 i nie listing katalogu. Klient pobiera ofertę wyłącznie podpisanym

linkiem, więc nie potrzebuje dostępu do katalogu.

Role, uprawnienia i profile handlowców

Aktywacja zakłada role `mp_handlowiec` („Handlowiec”) i `mp_manager` („Manager sprzedaży”) oraz dokłada uprawnienia wtyczki roli administrator. Uprawnienia są synchronizowane w obie strony przy każdej aktywacji — zawężenie działa więc także przy aktualizacji, nie tylko przy pierwszej instalacji.

Uprawnienia

- `mp_sw_handle_event` — obsługa zdarzeń procesu (wszystkie trzy role).
- `mp_sw_view_own` / `mp_sw_view_team` / `mp_sw_view_all` — zakres widoku: własne / zespół / cała firma.
- `mp_sw_change_status` — zmiana statusu procesu.
- `mp_sw_assign` — przypisanie procesu handlowcowi (manager, administrator).
- `mp_sw_manage_settings` — ustawienia wtyczki, w tym wznowienie zatrzymanej kolejki (administrator).

Zmiana zachowania przy aktualizacji

Manager nie ma już uprawnienia `mp_sw_manage_all` — widzi procesy swojego zespołu, nie całej firmy. Jeśli klient chce managera z pełnym widokiem, nadaj mu jawnie `mp_sw_view_all`.

Profil handlowca — cztery pola meta

Dobór handlowca do nowego zapytania działa na metadanych użytkownika. Wtyczka nie dokłada pól do ekranu profilu — ustawia się je przez WP-CLI albo narzędzie do edycji meta.

- `mp_sw_country` — kraj obsługiwany przez handlowca, dwie litery (np. PL). Wymagane.
- `mp_sw_langs` — języki po przecinku (np. pl,en). Wymagane.
- `mp_sw_team` — identyfikator zespołu (np. eksport). Wymagane; na nim opiera się widok managera.
- `mp_sw_active` — 0 wyłącza handlowca z doboru (urlop, odejście). Brak wartości oznacza „aktywny”.

Przykład: `wp user meta update 14 mp_sw_country PL && wp user meta update 14 mp_sw_langs "pl,en" && wp user meta update 14 mp_sw_team eksport`

Handlowiec z niepełnym profilem NIE jest po cichu pomijany — trafia na listę „do uzupełnienia”, a jego zapytania idą do managera. To zamierzone: brakująca konfiguracja ma być widoczna, a nie cicho gubić leady.

Metadane są chronione

Pola z prefiksem mp_ może zmieniać wyłącznie użytkownik z uprawnieniem promote_users. Zwykły handlowiec nie przepisze sobie zespołu ani kraju przez formularz profilu, bo uprawnienie edit_user ma każdy nad samym sobą — i to była właśnie luka do zamknięcia. Wywołania bez zalogowanego użytkownika (aktywacja, cron, WP-CLI, import) przechodzą normalnie.

Baza danych

Wtyczka zakłada pięć tabel z prefiksem `wp_mp_sw_`: `flow` (proces), `tasks` (zadania follow-up), `notifications` (kolejka e-mail), `activity` (dziennik), `events` (rejestr zdarzeń, idempotencja). Szczegóły kolumn i relacji są na schemacie bazy danych dołączonym do tej dokumentacji.

Wersja schematu: 0.4.0. Migracja idzie na haku `plugins_loaded`, czyli przy pierwszym wejściu na witrynę po wgraniu plików — nie ma osobnego przycisku „aktualizuj bazę”. Krok 0.3.0 → 0.4.0 usuwa z rejestru zdarzeń martwą kolumnę (`dbDelta` kolumn nie kasuje, więc idzie osobnym `ALTER-em`); kolumna była pusta w każdej instalacji, więc żadne dane nie giną. Dlatego kopia zapasowa przed wdrożeniem jest w tej instrukcji krokiem pierwszym, a nie ostatnim.

Funkcja `dbDelta` nie tworzy kluczy obcych, więc dwa więzy (`tasks.flow_id` i `notifications.flow_id` → `flow.id` `ON DELETE CASCADE`) zakłada osobny `ALTER`. Zakłada je tylko na InnoDB i tylko wtedy, gdy w tabelach nie ma wierszy-sierot — inaczej po cichu pomija, zamiast przerywać instalację.

Retencja: zdarzenia starsze niż 90 dni kasuje zadanie `mp_sw_retention`. Dziennik aktywności nie jest czyszczony nigdy — to on odtwarza historię procesu.

Smoke-test uprawnień po wdrożeniu

Załącz konto testowe z rolą Handlowiec i przejdź poniższe kroki zalogowany jako ono. Test wyłapuje najczęstszy błąd wdrożeniowy: rolę założone przy aktywacji, ale uprawnienia nadpisane wtyczką do zarządzania rolami.

1. Panel → Procesy sprzedażowe (`admin.php?page=mp-sales-workflow`). Strona się otwiera, widać wyłącznie procesy przypisane do tego konta.
2. Podmień w adresie identyfikator procesu na cudzy — oczekiwany wynik to „nie znaleziono procesu”, a nie „brak uprawnień”. Kod 403 potwierdzałby, że taki proces istnieje.
3. Wyloguj się i otwórz `admin-ajax.php?action=mp_sw_event` — odmowa. Żaden punkt wejścia wtyczki nie jest dostępny bez zalogowania.
4. Otwórz link do oferty z e-maila testowego — PDF się pobiera.
5. Zmień jeden znak w parametrze `mp_sw_sig` tego linku — „Link jest nieprawidłowy”.
6. Zaloguj się jako manager — widać procesy jego zespołu (`mp_sw_team`), nie całej firmy.

Po teście usuń albo dezaktywuj konto testowe.

Diagnostyka

Odmowy trafiają do dziennika technicznego (`error_log` PHP), nigdy do bazy — zalanie odrzucanego punktu wejścia nie może zapełnić dysku. W odpowiedzi HTTP widać wyłącznie

kod ze słownika, bez nazwy reguły i bez treści zapytania.

- MP3-E110 — zdarzenie przyszło niewłaściwym kanałem (macierz pochodzenia).
- MP3-E111 — próba odpalenia zadań poza kontekstem crona; sprawdź konfigurację crona.
- MP3-E140 — proces nie istnieje albo należy do kogoś innego (celowo nierozróżnialne).
- MP3-E150 — konflikt wersji: ktoś zmienił proces równolegle. Odśwież i powtórz.
- MP3-E170 / E171 — błąd wysyłki / zadziałał bezpiecznik kolejki.
- MP3-E180 / E181 — zły podpis linku / link wygaśł; jeden komunikat dla obu przypadków.

Deinstalacja

Usunięcie wtyczki nie kasuje danych. Zawsze sprzątane są: zadania cron, opcja `mp_sw_queue_halted` i transjenty poczty. Tabele i role znikają dopiero wtedy, gdy administrator świadomie włączy opcję: wp `option update mp_sw_delete_data 1`

Domyślnie wyłączone, bo dziennik aktywności jest kryterium odbioru projektu, a „usuń wtyczkę” bywa kliknięte przez pomyłkę.

Pełna checklista wdrożeniowa

Ten dokument streszcza konfigurację. Rozszerzona checklista z gotowymi blokami konfiguracji nginx i Apache jest w pliku `docs/WDROZENIE.md` w katalogu wtyczki.